

Do caminho de ataque ao modelo de ameaças

Missão: modelar o sistema da empresa fictícia, conduzir um tabletop de ransomware sem malware e defender um tratamento verificável.

Duração	Equipe	Entrega
52 minutos	3–4; papéis rotativos	um PDF por grupo

Objetivos

- Representar fluxos, ativos e fronteiras de confiança.
- Formular ameaças testáveis e três caminhos de ataque.
- Priorizar risco, tratamento e validação.

Recursos

- Threat Dragon, diagrams.net, Mermaid ou papel A3.
- Inventário da A02 e cartões deste roteiro.

ATENÇÃO

Tabletop apenas. Não execute malware, payload, criptografia, varredura, persistência ou indisponibilidade. Pare diante de destino externo, dado real ou efeito operacional.

Hipótese inicial

Registre um caminho provável, uma explicação alternativa e a evidência que diferenciaria as duas.

Etapa 1 — Sistema e fronteiras (10 min)

Desenhe suporte remoto, VPN, servidor de arquivos, estação de engenharia, jump host, supervisor e processo. Nomeie fluxos e marque pelo menos duas fronteiras.

EVIDÊNCIA

O diagrama deve mostrar direção, dado/comando e mudança de confiança; uma linha sem rótulo não basta.

Etapa 2 — STRIDE e caminhos (15 min)

Formule ao menos três ameaças no formato agente + condição + elemento + consequência + evidência. Construa: caminho TI, caminho rumo a OT e caminho interrompido por controle.

Caminho	Evidência	Suposição	Consequência
TI			
TI → OT			
interrompido			

Etapa 3 — Tabletop (14 min)

O professor revelará cartões. A cada evento, atualize o modelo, declare coleta segura, decisão e critério de parada.

Cartão	Decisão	Evidência necessária	Efeito no risco
A — backup íntegro?			
B — conta compartilhada			
C — sessão OT			

DECISÃO

Não existe resposta universal. Registre premissa, autoridade necessária e impacto sobre disponibilidade e safety.

Etapa 4 — Tratar e validar (9 min)

Risco	Tratamento	Responsável	Validação

Etapa 5 — Revisão e entrega (4 min)

- Outra equipe consegue seguir os caminhos e localizar fronteiras?

- Evidências e suposições estão separadas?
- Controle preserva operação e possui reteste?

Entrega

Envie A03-grupo-NN.pdf com diagrama, três caminhos, ameaças, registro de risco, tratamento, validação e reflexão. Não inclua credenciais, IPs públicos ou dados reais.

Rubrica

Critério	Atendeu	Parcial
Modelo	fluxos e fronteiras legíveis	componentes sem relações
Ameaças	testáveis e ligadas ao desenho	listas genéricas
Taxonomias	uso correto e justificado	mapeamento forçado
Risco	consequência e tratamento	prioridade sem impacto
Validação	evidência e risco residual	controle sem teste

Limpeza e transferência

- Feche ferramentas e preserve somente o PDF sanitizado.
- Descarte cartões e notas com dados não sanitizados.
- Confirme que nenhum serviço ou artefato ofensivo foi criado.

Transferência: se a conexão TI/OT fosse removida, que operação legítima seria perdida e que acesso emergencial surgiria?

Fontes

- NIST CSF 2.0; MITRE CAPEC; MITRE ATT&CK Enterprise e ICS; OWASP Threat Modeling.